



**IN RE: DATASCOPE COMMUNICATIONS
(PHILIPPINES), INC.**

NPC BN 18-140

X-----X

RESOLUTION

NAGA, P.C.;

Before the Commission is the compliance of Datascope Communications (Philippines), Inc. (Datascope) with the Orders of the National Privacy Commission (NPC) through its Complaints and Investigation Division (CID) dated 19 October 2020 and 14 June 2021.

Facts

On 31 July 2018, Datascope submitted to the Commission its initial breach report relating to a data breach that occurred on 05 February 2018.¹ In its initial report, Datascope narrated that as part of its Business Continuity Management, it conducts a backup of its personnel employment records.² Datascope explained that as part of its procedure:

The personnel employment records are being scanned and saved in the external [hard drive] HDD and on a monthly basis[,] the HDD is being swapped and transferred to the other facility.³

In stating what occurred prior to the occurrence of the incident, Datascope narrated:

¹ Mandatory Notification and Report dated 31 July 2018 of Datascope Communications (Philippines), Inc., at p. 1.

² *Id.*, at p. 2.

³ *Id.*

On November 28, 2017, the HR Analyst, CC who is in-charge in the scanning of personnel employment records, transferred from TARA facility to MMP Facility. She brought the external HDD from TARA Facility to MMP Facility to continue her task of scanning, but according to her she forgot to secure an approved gate pass during the transfer. CC was then able to use the external HDD in MMP Facility.

During the monthly swapping of external HDD for the month of December in MMP Facility (the monthly swapping is usually being done at the end of the month), the SND Staff, MJ approached CC on December 29, 2017 to collect the said external HDD from her, however CC was not able to provide the external HDD because she assumed that the disk might be in the other facility. CC, together with other HR staff started searching of the missing hard drive for the 2 facilities but was not able to find it.⁴

Upon investigation conducted by Datascope, it was revealed that:

1. When CC transferred to MMP Facility on November 28, 2017, she brought the [HDD] from TARA Facility to MMP Facility. She forgot to secure an approved gate pass, thus there is no proof that the [HDD] was transferred.
2. Upon checking her workstation in MMP Facility, it was confirmed that the [HDD] was used with last transaction dated November 28, 2017.
3. CC forgot to safe keep the [HDD] before she went on leave from December 23-27, 2017.
4. Upon her return to work on December 29, 2017, MJ started looking for the HDD, but CC requested for more time to look for the HDD.
5. On January 5, 2018, she was approached again by MJ but CC cannot provide the HDD.
6. On the next swapping of hard disk for the month of January (end of January), CC still was not able to provide the hard disk thus the missing hard drive was reported to the incident Response Team Coordinator on February 5, 2018.

⁴ *Id.*

7. The result of the investigation cannot establish whether the external HDD was misplaced or intentionally taken.⁵

Datascope also stated that in estimation, there were three hundred sixty-six (366) active employees and two hundred thirty-seven (237) resigned employees whose data contained in their 201 files were compromised by the incident.⁶ Moreover, Datascope reported that the data in the 2015 BIR Form 2316 of four hundred thirty-eight (438) active employees and eighty (80) resigned employees were also affected.⁷

Moreover, the initial report of Datascope enumerated the personal data contained in the missing external HDD were: (1) full name; (2) date of birth; (3) address; (4) contact information; (5) SSS number; (6) tax identification number; (7) BIR Form 2316; (8) Philhealth number; (9) PAG-Ibig number; (10) education/transcripts/diplomas; (11) performance assessments; (12) disciplinary actions; (13) work history; (14) post-employment information; (15) hiring requirements; and (16) annual medical records, among others.⁸

The initial report of Datascope also identified the vulnerabilities that allowed the breach: (1) non-encryption of HDD; (2) HRD staff room is accessible by other staff; and (3) No CCTV inside the HRD staff room.⁹

In view of the foregoing, Datascope stated that the personal data breach can result into identity theft of personal data which can be used for blackmailing or extortion, and coercion, as well as access to personal data which can result to “reputation or financial damage or could be sold to telemarketers.”¹⁰

Thus, Datascope described the safeguards in place to avoid the recurrence of the same incident, which include the: (1) use of gate

⁵ Mandatory Notification and Report dated 31 July 2018 of Datascope Communications (Philippines), Inc., at pp. 2-3.

⁶ *Id.*, at p. 3.

⁷ *Id.*

⁸ *Id.*, at p. 4.

⁹ Mandatory Notification and Report dated 31 July 2018 of Datascope Communications (Philippines), Inc., at p. 3.

¹⁰ *Id.*, at pp. 3-4.

pass when transferring removable media; (2) use of company vehicle when transferring removable media; (3) HRD staff room is locked when unattended; (4) there is a dedicated workstation where external HDD should be used; (5) workstation is password protected.¹¹

Lastly, Datascope reported on the details of the remedial measures it undertook to address the breach:

a) Description of the measures taken or proposed to be taken to address the breach

1. We conducted thorough searching of the missing hard drive.
2. We conducted administrative hearing.
3. Enforcement of disciplinary action to the concerned HR staff.
4. We conducted a meeting with HRD staff on the importance and confidentiality of the data that HRD handled.
5. We temporarily suspend the scanning of employees' records.

b) Actions being taken to secure or recover the personal data that were compromised

Since the missing HDD was a backup copy thus we perceived that there is no [loss] of data. We still hold a copy of the personnel employment records both in soft and hard copies in our HR storage room however the lost hard drive poses a potential exposure and may compromise employees' personal information.

Further when the incident was discovered it underwent incident management process as follows:

1. The Incident Response Team conducted an investigation.
2. As part of the investigation and mitigation process, the Accounting Department was tasked to conduct a physical audit of all external HDD issued to HR Department.
3. A Corrective Action Report was issued to the HR Head. The HR Head was required to provide root cause analysis of the incident and corrective action plan in a given period.
4. All the HRD personnel including the utility clerks and company driver were asked to submit their answer on the below questions in a written form during the same period:

¹¹ *Id.*, at p. 3.

- a) What are their knowledge with regards to keeping HRD files secured
 - b) What are their awareness with HRD files
 - c) What are their practices in keeping HRD rooms secured
- c) Actions performed or proposed to mitigate possible harm or negative consequences and limit the damage or distress to those affected by the incident –

As of today, there is no indication that the data were compromised, because there are no complaints or claims against the company pertaining to personnel employment records.

- d) Action being taken to inform the data subjects affected by the incident or reasons for any delay in the notification –

We plan to inform the data subjects by August 3, 2018 upon completion of the Mandatory Personal Data Breach Notification to Data Subjects.

- e) Measures being taken to prevent a recurrence of the incident. –

1. We formulated written guidelines in the proper scanning and back up of HR files to include that external hard disk containing sensitive information shall be attached solely to the workstation located inside the HR inner room where the HR Head is located.
2. We defined the access and restrictions of the HR staff with regards to their access to confidential information of personnel employment records.
3. We implemented a monthly monitoring and inspection of external HDD.
4. We installed a CCTV camera inside the HRD room due to the incident.
5. We will implement encryption for the external HDD with confidential files.
6. We will create a procedure for pick up and transfer of hard drives aside from the logs. (Specifically include in the procedure that refusal of pickup of HDD is not allowed).
7. We will allocate a dedicated server for HRD back up files to be stored inside the Data Center.¹²

¹² *Id.*, at pp. 4-6.

On 19 October 2020, the NPC through its CID issued an Order requiring Datascope to submit a Full Report “expounding the details of the incident with emphasis supplied on the lacking information from the initial notification report” within fifteen (15) days from the receipt of such Order.¹³

On 03 November 2020, Datascope submitted its compliance with the abovementioned Order dated 19 October 2020.¹⁴ In the said compliance, Datascope specifically stated that the total number of affected data subjects is six hundred fifty-one (651) broken down into: (1) three hundred eighty-four (384) active employees; (2) two hundred sixty (260) resigned employees; (3) seven (7) employees on leave.¹⁵ According to Datascope, the inconsistency in the number of affected data subjects from its Initial Report was due to the fact that “data subjects that were listed under “201 files” were also listed under the “2015 BIR Form 2316[.]””¹⁶ Aside from specifically identifying the number of data subjects, Datascope reiterated the details contained in its initial report attaching therewith the following:

1. Collection and Swapping Procedure of External HDD;
2. Personal Information Protection Guidelines;
3. Guidelines in the Scanning of 201 Files and Procedure in the Proper Safekeeping of External HDD;
4. Organizational Records Protection Procedures;
5. Incident Report Form from the Incident Response Team;
6. Gate Pass Procedure and Guidelines;
7. Removable Media Guidelines;
8. Media Transport Procedure;
9. Physical Security Perimeter Guidelines;
10. Clear Desk-Clear Screen and Unattended User Equipment Policy;
11. Root Cause Analysis of the investigation conducted;
12. Corrective Action Report from the HR Department;
13. Report on the thorough searching of missing HDD;
14. Interview/written statements of HR Department Staff;

¹³ NPC BN 18-140 (*unreported*), Order dated 19 October 2020 of the National Privacy Commission’s Complaints and Investigation Division.

¹⁴ Full Report on the Personal Data Breach dated 03 November 2020 of Datascope Communications (Philippines), Inc.

¹⁵ *Id.*, at p. 3.

¹⁶ *Id.*, at p. 7.

15. Internal Memorandum containing the Mandatory Personal Data Breach Notification to Data Subjects;
16. Proof of awareness training and orientation conducted;
17. Documented Information Control Guidelines and Procedures;
18. Manual on the List of Access Rights;
19. Monitoring Log of External HDD;
20. Proof of installed CCTVs in the HR Department; and,
21. Proof of encryption of payroll HDD.¹⁷

Subsequently, CID issued an Order dated 14 June 2021 requiring Datascope to submit the following:

1. [T]he Audit Report containing the result of the physical audit of all external HDDs conducted by the Accounting Department; and
2. [T]he result of the Privacy Impact Assessment (PIA) on the identification of privacy risks and adaption of the appropriate security measures to protect personal data against natural and human dangers with guidelines provided under NPC Advisory No. 2017-03 particularly on the process of scanning of employment record and transfer thereof of HDDs, and the handling, transport and storage of such HDDs containing backup copy of personal data.¹⁸

Accordingly on 19 May 2022, Datascope submitted to the Commission's CID the above-requested documents.¹⁹

Issue

Whether Datascope has sufficiently complied with the Orders dated 19 October 2020 and 14 June 2021.

Discussion

In the Order of the CID dated 19 October 2020, Datascope was required to submit a Full Report "expounding the details of the

¹⁷ *Id.*, referred to as Annexes "1" to "21."

¹⁸ NPC BN 18-140 (*unreported*), Order dated 14 June 2021 of the National Privacy Commission's Complaints and Investigation Division.

¹⁹ Additional Documents dated 19 May 2022 of Datascope Communications (Philippines), Inc.

incident” and “attaching the specified documents” to be used in the investigation of the breach incident.²⁰

On the other hand, another Order dated 14 June 2021 was issued by the CID requiring Datascope to submit the following documents: (1) Audit Report containing the result of the physical audit of all external HDDs; and (2) Result of the Privacy Impact Assessment (PIA) which Datascope has conducted.²¹

The Commission finds Datascope’s submissions to be sufficiently compliant with the abovementioned Orders.

- I. *Datascope sufficiently provided the details in its Full Report pursuant to NPC Circular 16-03.*

On 19 October 2020, Datascope was required by CID to submit a Full Report “expounding the details of the incident” and “attaching the specified documents” to be used in the investigation of the breach incident, pursuant to Section 17(D) of NPC Circular 16-03 (Personal Data Breach Management).²² Likewise, an Order dated 14 June 2021 was issued by CID requiring Datascope to submit an Audit Report containing the result of the physical audit of all external HDDs.²³

In order to promote cooperation with the personal information controller (PIC) regarding investigations on matters relating to personal data breach, Rule V, Section 17(D) of NPC Circular 16-03 requires such PIC to notify the Commission of the incident which shall contain the following details:

- D. *Content of Notification.* The notification shall include, but not be limited to:

1. Nature of the Breach

²⁰ NPC BN 18-140 (*unreported*), Order dated 19 October 2020 of the National Privacy Commission’s Complaints and Investigation Division.

²¹ *Id.*

²² *Id.*

²³ *Id.*

- a. description of how the breach occurred and the vulnerability of the data processing system that allowed the breach;
 - b. a chronology of the events leading up to the loss of control over the personal data;
 - c. approximate number of data subjects or records involved;
 - d. description or nature of the personal data breach;
 - e. description of the likely consequences of the personal data breach; and
 - f. name and contact details of the data protection officer or any other accountable persons.
2. Personal Data Possibly Involved
- a. description of sensitive personal information involved; and
 - b. description of other information involved that may be used to enable identity fraud.
3. Measures Taken to Address the Breach
- a. description of the measures taken or proposed to be taken to address the breach;
 - b. actions being taken to secure or recover the personal data that were compromised;
 - c. actions performed or proposed to mitigate possible harm or negative consequences, and limit the damage or distress to those affected by the incident;
 - d. action being taken to inform the data subjects affected by the incident, or reasons for any delay in the notification;
 - e. the measures being taken to prevent a recurrence of the incident.

The Commission reserves the right to require additional information, if necessary.²⁴

To comply with the Order to submit its Full Report, Datascope forwarded to the Commission its compliance providing the required information.²⁵ Datascope reiterated the details provided in its initial

²⁴ National Privacy Commission, Personal Data Breach Management, NPC Circular 16-03, rule V, § 17(D) (15 December 2016) (NPC Circular 16-03).

²⁵ Full Report on the Personal Data Breach dated 03 November 2020 of Datascope Communications (Philippines), Inc.

report, attaching therein a “flowchart for the collection and swapping procedure of external HDD” as well as its “restoration procedure.”²⁶

In the Collection and Swapping Procedure of External HDD, according to Datascope, the System Administrator will send to the authorized personnel an email notification for the collection of external HDDs.²⁷ Thereafter, upon checking the completeness of external HDDs to be picked-up, the external HDD’s envelope shall be sealed in front of the owner and the owner to “put his/her signature on the envelope” and thereafter sign the same in a logbook.²⁸ As part of its procedure, Datascope also stated that if there are unavoidable circumstances during the collection and swapping of external HDDs, the owner shall write such reason in the logbook.²⁹ Also, the external HDDs shall be transported to MMP and TARA Facility and vice versa every end of the month for offsite back-up and safekeeping.³⁰ The procedure also includes the preparation and accomplishment of a gate pass before transferring the HDDs to other facility.³¹ Lastly, once the external HDD becomes full, the deletion or reformatting of the files shall be with the approval of the owner.³²

As to the Restoration Procedure, notification regarding data loss must be made within one (1) business day, providing thereof the file names and the description of the files.³³ The procedure likewise provided that the restoration’s response time will be variable, but “users should anticipate approximately six (6) business hours to restore data.”³⁴ Once data restoration was done, the integrity of the data must be verified.³⁵

As to the safeguards it took to mitigate the impact of the data breach, Datascope submitted the following documents: (1) Personal

²⁶ *Id.*

²⁷ *Id.*, referred to as Annex “1.”

²⁸ *Id.*

²⁹ Full Report on the Personal Data Breach dated 03 November 2020 of Datascope Communications (Philippines), Inc., referred to as Annex “1.”

³⁰ *Id.*

³¹ *Id.*

³² *Id.*

³³ Full Report on the Personal Data Breach dated 03 November 2020 of Datascope Communications (Philippines), Inc., referred to as Annex “1.”

³⁴ *Id.*

³⁵ *Id.*

Information Protection Guidelines;³⁶ (2) Guideline in the scanning of 201 files and procedure in the proper safekeeping of external HDD;³⁷ and (3) Organizational records protection procedures.³⁸

In its Personal Information Protection Guidelines, Datascope stated that the 201 files of its employees “are disposed after 4 years of separation” from the company.³⁹ The document also provided that the Human Resources (HR) Head acts as the data protection officer (DPO) of the company who shall:

[O]versee the compliance of the organization with the [Data Privacy Act of 2012] DPA, its [Implementing Rules and Regulations] IRR, and other related policies, including the conduct of [PIA], implementation of security measures, security incident and data breach protocol, and the inquiry and complaints procedure.⁴⁰

Moreover, the Personal Information Protection Guidelines provided for the precautionary measures in protecting its clients’ or customers’ personal data such as:

1. All the employees undergo the ISMS policy orientation including the new hires.
2. Employees sign the Undertaking of Confidentiality (non-disclosure agreement).
3. Employees sign the Job Description stating their responsibility to ensure compliance to the ISMS.⁴¹

Lastly, the following personnel are authorized to process the statutory and government benefits:

1. HR Specialist- for Production employees (Data Entry and Search).
2. Senior Accountant- for staff employees.
3. Accounting Head- for department heads.⁴²

³⁶ *Id.*, referred to as Annex “2.”

³⁷ Full Report on the Personal Data Breach dated 03 November 2020 of Datascope Communications (Philippines), Inc., referred to as Annex “3.”

³⁸ *Id.*, referred to as Annex “4.”

³⁹ *Id.*, referred to as Annex “2.”

⁴⁰ *Id.*

⁴¹ Full Report on the Personal Data Breach dated 03 November 2020 of Datascope Communications (Philippines), Inc., referred to as Annex “2.”

⁴² *Id.*

The procedure for processing of the abovementioned benefits shall be as follows:

1. Payment for SSS and Pag-IBIG are transmitted by the Accounting Head thru online facility. Payment for PhilHealth is done manually thru bank.
2. Submission of reports are done by the messenger. The messenger signed Undertaking of Confidentiality.
3. The loan application, registration and update are submitted by the employees to HR Staff. There documents are recorded in the incoming documents log.
4. HR staff ensure utmost protection of received documents until it is submitted to the government agencies.⁴³

As regards the Guidelines in the Scanning of 201 Files and Procedure in the Proper Safekeeping of External HDD, Datascope stated that “only the allocated PC” located inside the HR Head’s room, shall be used when scanning the 201 files.⁴⁴ In the same document, Datascope shall undertake the following security measures for the safekeeping of external HDD:

1. The external HDD should be labeled for proper identification.
2. The external HDD shall be attached only to the allocated PC during the scanning activity and to be detached once the scanning activity is finished.
3. When not in use, the external HDD should be properly stored in the process owner’s cabinet.
4. The external HDD will be copied by SND staff on a monthly basis for back-up purposes.
5. Bac-up copy of external HDD is taken care of by SND.
6. Both external HD of HRD and SND are to be encrypted.
7. The external HDD shall not be transferred to the other facility without prior approval of the HR and ISMR.⁴⁵

As to the Organizational Records Protection Procedures, Datascope stated that HR documents in hard copies, including employees’ records, shall be kept safely in the HR stockroom where only the HR

⁴³ *Id.*

⁴⁴ *Id.*, referred to as Annex “3.”

⁴⁵ Full Report on the Personal Data Breach dated 03 November 2020 of Datascope Communications (Philippines), Inc., referred to as Annex “3.”

staff has access.⁴⁶ Moreover, 201 files shall be accessible only to HR assistant, specialist, head, and general manager of Datascope.⁴⁷

Datascope also attached in its Full Report a Formal Incident Report containing a recommendatory action from Datascope's Incident Response Team:

1. Implement encryption for the external [HDD] with confidential files.
2. Make an equipment inventory to make sure that it is not just the [HDD] that is missing.
3. Monitoring/inspection log of external [HDDs].
4. Ensure external [HDDs] were swapped every month even without changes/updates.
5. Strict implementation: always have a transmittal/gate pass to serve as proof that the item was being transferred.⁴⁸

In line with the recommendations made by its Incident Response Team, Datascope also submitted the following documents to serve as proof of security measures it implemented:

1. Gate Pass Procedure and Guidelines⁴⁹
2. Removable Media Guidelines⁵⁰
3. Media Transport Procedure⁵¹
4. Physical Security Perimeter Guidelines⁵²
5. Clear Desk-Clear Screen and Unattended User Equipment Policy⁵³
6. Documented Information Control Guidelines and Procedures.⁵⁴

Moreover, Datascope attached a full investigation report containing the result of the investigation conducted by its Incident Response Team.⁵⁵ On account of the said investigation report, Datascope

⁴⁶ *Id.*, referred to as Annex "4."

⁴⁷ *Id.*

⁴⁸ *Id.*, referred to as Annex "5."

⁴⁹ Full Report on the Personal Data Breach dated 03 November 2020 of Datascope Communications (Philippines), Inc., referred to as Annex "6."

⁵⁰ *Id.*, referred to as Annex "7."

⁵¹ *Id.*, referred to as Annex "8."

⁵² *Id.*, referred to as Annex "9."

⁵³ Full Report on the Personal Data Breach dated 03 November 2020 of Datascope Communications (Philippines), Inc., referred to as Annex "10."

⁵⁴ *Id.*, referred to as Annex "17."

⁵⁵ *Id.*, referred to as Annex "12."

likewise attached the Corrective Action Report which contained the following details:

Immediate Corrective Action:

1. Conducted thorough searching of the missing equipment.
2. Reminded all the HR staff about the proper storing of HR files including external [HDD] and the impact of the incident to the company and employees in general.⁵⁶

Corrective Action Plans:

1. Draft a written guideline in the proper scanning and back up of HR files to include that external [HDD] containing sensitive information shall be attached solely to workstation located inside the HR Head's room.
2. Monitoring/inspection of external [HDDs] on a monthly basis.
3. Implement encryption for the external [HDD] with confidential files.⁵⁷

Further, as part of its investigation, Datascope stated that its Accounting Department conducted a physical audit of all external HDD issued to HR Department.⁵⁸

Datascope also asked all HRD personnel, as well as the utility clerks and company driver, to answer the following questions on a written form:

- a) What [is] their knowledge with regards *sic* to keeping HRD files secured?
- b) What [is] their awareness with HRD files?
- c) What are their practices in keeping HRD rooms secured?⁵⁹

In answering the above-mentioned questions, the HRD personnel, utility clerks and company driver stated that the files are properly safe kept in cabinet in the HRD room.⁶⁰ The said employees and

⁵⁶ *Id.*, referred to as Annex "13."

⁵⁷ Full Report on the Personal Data Breach dated 03 November 2020 of Datascope Communications (Philippines), Inc., referred to as Annex "12."

⁵⁸ *Id.*, at p. 6.

⁵⁹ *Id.*

⁶⁰ *Id.*, referred to as Annex "14."

personnel also stated that the HRD files are confidential in nature, and as a practice, the HRD room must always be locked and ensure that no unauthorized person is left inside.⁶¹

Likewise in its Full Report, Datascope made a detailed report on the measures it took to prevent a recurrence of the incident:

1. DCPI formulated written guidelines in the proper scanning and back up of HR files to include that external hard disk containing sensitive information shall be attached solely to the workstation located inside the HR inner room where the HR Head is located.
2. DCPI defined the access and restrictions of the HR staff with regards to their access to confidential information of personnel employment records.
3. DCPI implemented a monthly monitoring and inspection of external HDD.
4. DCPI installed a CCTV camera inside the HRD room due to the incident.
5. DCPI will implement encryption for the external HDD with confidential files.
6. DCPI will create a procedure for pick up and transfer of hard drives aside from the logs recording the movement of the hard drives and chain of custody handling. (Specifically include in the procedure that refusal of pickup of HDD is not allowed).
7. DCPI will allocate a dedicated server for HRD back up files to be stored inside the Data Center.⁶²

Datascope also submitted proof of training attendance of its employees in relation to compliance with cyber safety and data privacy.⁶³

As one of Datascope's security management, Datascope submitted a List of Access Rights of the company personnel and/or staff who are

⁶¹ Full Report on the Personal Data Breach dated 03 November 2020 of Datascope Communications (Philippines), Inc., referred to as Annex "14."

⁶² *Id.*, at pp. 7-8.

⁶³ *Id.*, referred to Annex "16."

authorized to access company documents related to its employees such as employment contract, payroll approval, and claims for SSS, Pag-IBIG, and PhilHealth, among others.⁶⁴

Datascope also attached a copy of its inventory conducted by the Accounting Department on the HRD external HDDs containing details of which facility where such HDDs are found, as well as their specifications, and the personnel who are accountable to such external HDDs.⁶⁵

Finally, Datascope submitted photographs of the closed-circuit television (CCTV) installed inside the HRD room,⁶⁶ and proof of payroll with encryption.⁶⁷

Upon review of the Full Report and the attached documents, Datascope was able to include the details that were lacking from its initial report. Thus, the Commission finds that Datascope sufficiently complied with the Orders dated 19 October 2020 and 14 June 2021.⁶⁸

*II. Datascope submitted a PIA
on its various data
processing systems.*

In an Order dated 14 June 2021, the CID required Datascope to submit the following:

1. the Audit Report containing the results of the physical audit of all external HDDs conducted by the Accounting Department; and
2. the result of the Privacy Impact Assessment (PIA) on the identification of privacy risks and adaption of the appropriate measures to protect personal data against natural and human dangers with guideline provided under NPC Advisory No.

⁶⁴ *Id.*, referred to Annex “18.”

⁶⁵ Full Report on the Personal Data Breach dated 03 November 2020 of Datascope Communications (Philippines), Inc., referred to Annex “19.”

⁶⁶ *Id.*, referred to Annex “20.”

⁶⁷ *Id.*, referred to Annex “21.”

⁶⁸ NPC BN 18-140 (*unreported*), Order dated 19 October 2020 of the National Privacy Commission’s Complaints and Investigation Division. *See also* NPC BN 18-140 (*unreported*), Order dated 14 June 2021 of the National Privacy Commission’s Complaints and Investigation Division.

2017-03 particularly on the process of scanning of employment record and transfer thereof of HDDs, and the handling, transport and storage of such HDDs containing backup copy of personal data.⁶⁹

Accordingly, Datascope submitted to the Commission the required PIA on 19 May 2022.

NPC Advisory No. 2017-03 defines a PIA as a:

[P]rocess undertaken and used to evaluate and manage impacts on privacy of a particular program, project, process, measure, system or technology product of a PIC or PIP program, project process, measure, system or technology product of a PIC or PIP. It takes into account the nature of the personal data to be protected, the personal data flow, the risks to privacy and security posed by the processing, current data privacy best practices, the cost of security implementation, and, where applicable, the size of the organization, its resources, and the complexity of its operations.⁷⁰

Datascope's PIA provided and tabulated the observations, recommendations, and a corresponding management action plan related to the general data privacy principles of transparency, legitimate purpose, and proportionality;⁷¹ the privacy impact analyses on the collection, and the use and disclosure of personal data;⁷² the preservation of the quality of personal data being processed;⁷³ organizational, physical, and technical security measures;⁷⁴ and, a privacy risk assessment or management as to the disposal of personal data.⁷⁵

⁶⁹ NPC BN 18-140 (*unreported*), Order dated 14 June 2021 of the National Privacy Commission's Complaints and Investigation Division.

⁷⁰ National Privacy Commission, Guidelines on Privacy Impact Assessments, NPC Advisory 2017-03, in Definition of Terms (31 July 2017) (NPC Advisory 2017-03).

⁷¹ Additional Documents dated 19 May 2022 of Datascope Communications (Philippines), Inc., referred to as Privacy Impact Assessment, at pp. 16-30.

⁷² *Id.*, at pp. 31-40.

⁷³ *Id.*, at pp. 41-45.

⁷⁴ *Id.*, at pp. 46-60.

⁷⁵ Additional Documents dated 19 May 2022 of Datascope Communications (Philippines), Inc., referred to as Privacy Impact Assessment at pp. 61-65.

First, Datascope's PIA included an assessment of its data processing systems, specifically on the scanning of 201 files of the company's regular employees.⁷⁶ According to Datascope, the scanning of the said 201 files will serve as its back up copy of the employees' records.⁷⁷ Datascope enumerated the personal data it collects, such as the employees' names, addresses, dates of birth, contact information, government identification numbers, transcripts or diplomas, performance assessments, disciplinary actions, work histories, post-employment information, hiring requirements, and annual medical results.⁷⁸

The process flow for the scanning activity of the 201 files were also provided in the PIA.⁷⁹ Datascope mentioned that the HR Analyst shall be responsible for the handling and processing of the personal data contained in the 201 files as well as other HR documents.⁸⁰ Datascope likewise mentioned that the personal data it collects shall be retained for four (4) years upon the separation of the employee from the company, after which, the personal data shall be disposed through deletion.⁸¹

Datascope added that its HR Analyst shall be responsible for the disposal of the personal data it collects, including the security measures it will take to implement such disposal.⁸² Datascope stated in its PIA that the external HDD containing personal data is being disclosed by transferring it to other facility for offsite backup.⁸³ Datascope likewise mentioned in its PIA that the nature, purpose, and extent of processing of personal data of its data subjects was made aware to them.⁸⁴

As regards the adherence to the general data privacy principle of transparency, Datascope stated that the data subjects are "aware of the risks and safeguards involved in the processing of [their]

⁷⁶ *Id.*, referred to as Privacy Impact Assessment at pp. 1-5.

⁷⁷ *Id.*

⁷⁸ *Id.*

⁷⁹ Additional Documents dated 19 May 2022 of Datascope Communications (Philippines), Inc., referred to as Privacy Impact Assessment at pp. 6-10.

⁸⁰ *Id.*

⁸¹ *Id.*

⁸² *Id.*, at pp. 11-15.

⁸³ Additional Documents dated 19 May 2022 of Datascope Communications (Philippines), Inc., referred to as Privacy Impact Assessment at pp. 11-15.

⁸⁴ *Id.*, at pp. 11-15.

personal data” as well as their data subject rights and on how these rights are exercised.⁸⁵ Datascope also indicated that there are “steps in place to allow an individual to know what personal data it holds about [him or her] and its purpose of collection, usage, and disclosure.”⁸⁶ Datascope specified that these policies for the management of personal data are being set out in the company’s Privacy Notice and Privacy Manual.⁸⁷

As to the Legitimate Purpose principle, Datascope indicated in its PIA that its “processing of personal data [is] compatible with a declared and specified purpose which are not contrary to law, morals, or public policy.”⁸⁸ The PIA also identified that data subjects are aware of the identity of the company as personal information controller (PIC) which processes their personal data, and on how the company’s DPO will be contacted.⁸⁹

Lastly, Datascope indicated that its data processing is “adequate, relevant, suitable, necessary, and not excessive in relation to a declared and specified purpose,”⁹⁰ in adherence to the Proportionality principle.⁹¹ In addition thereto, the PIA also stated that the processing of personal data was “authorized by a specific law or regulation, or by the individual through express consent.”⁹²

The PIA of Datascope also contains Privacy Impact Analyses of its personal data collection and, use and disclosure processes.⁹³ In collecting the personal data, Datascope stated that the collection and processing of personal data are made available in its Privacy Notice.⁹⁴ Datascope indicated that the consent of data subjects is “time-bound in relation to the declared, specified, and legitimate purpose.”⁹⁵

⁸⁵ *Id.*, at pp. 16-20.

⁸⁶ *Id.*

⁸⁷ Additional Documents dated 19 May 2022 of Datascope Communications (Philippines), Inc., referred to as Privacy Impact Assessment at pp. 16-20.

⁸⁸ *Id.*, at pp. 21-25.

⁸⁹ *Id.*

⁹⁰ *Id.*, at pp. 26-30.

⁹¹ Additional Documents dated 19 May 2022 of Datascope Communications (Philippines), Inc., referred to as Privacy Impact Assessment at pp. 26-30.

⁹² *Id.*

⁹³ *Id.*, at pp. 31-35.

⁹⁴ *Id.*

⁹⁵ Additional Documents dated 19 May 2022 of Datascope Communications (Philippines), Inc., referred to as Privacy Impact Assessment at pp. 31-35.

Datascope likewise mentioned that it collects the personal data directly from the concerned individual, as well as the capacity of data subjects to withdraw their consent in the processing of their personal data.⁹⁶ Datascope also maintained that the personal data will only be used or disclosed for its primary purposes.⁹⁷

Moreover, as to the quality of data being processed by Datascope, the PIA identified the following steps it takes to “ensure that all data that is collected, used, or disclosed will be accurate, complete, and up to date:”

1. A disposal schedule in place that deletes information that is over the retention period.
2. Staff are trained in the use of the tools and receive periodic updates.
3. Incidents are reviewed for lesson learnt and systems/processes updated appropriately.⁹⁸

In implementing organizational security, Datascope’s PIA indicated that it has appointed a company’s DPO or Compliance Officer, as well as the existence of data protection and security measure policies within the organization.⁹⁹ Datascope ensured that it has an inventory of the company’s data processing systems, and that all the personnel or employees who are processing through its data processing systems shall process personal data with strict confidentiality especially “if the personal data are not intended for public disclosure.”¹⁰⁰

On the other hand, Datascope’s physical security includes the following:

1. Policies and procedures to monitor and limit the access to this project/system.
2. Duties, responsibilities, and schedule of the individuals that will handle the personal data processing are clearly defined.

⁹⁶ *Id.*

⁹⁷ *Id.*, at pp. 36-40.

⁹⁸ *Id.*, at pp. 41-45.

⁹⁹ Additional Documents dated 19 May 2022 of Datascope Communications (Philippines), Inc., referred to as Privacy Impact Assessment at pp. 46-50.

¹⁰⁰ *Id.*

3. Inventory of processing systems.¹⁰¹

As regards technical security, Datascope provides for the following:

1. Security policy with respect to the processing of personal data.
2. Policies and procedures for the restoration of availability and access to personal data when security incidents occur.
3. Regular test, assessment, and evaluation of the effectiveness of security measures.
4. Encryption of personal data processed while in transit or at rest.¹⁰²

Lastly, Datascope has identified threats, vulnerabilities, and the existing controls it implemented to address such threats and vulnerabilities.¹⁰³

As a procedure of Datascope’s disposal of personal data which it collected, Datascope stated that “[o]nce the data is due for deletion as per the retention period, the data is deleted, and the external HDD is being re-used for the same purpose which is to store backup of 201 file.” Accordingly, Datascope identified the following threats and their vulnerabilities, as well as the controls it has implemented:

Threats	Vulnerabilities	Existing controls
Loss of data due to loss of external HDD.	Lack of established guidelines in the scanning of 201 files and proper safekeeping of external HDD.	1. With written guidelines in the scanning of 201 files and proper safekeeping of external HDD. 2. Defined the access and restrictions of the HR staff with access to confidential information of personnel employment records. 3. Monthly monitoring and inspection of external HDD. 4.Installation of CCTV camera inside the HRD room. 5. Encryption of external HDD with personal data.

¹⁰¹ *Id.*, at pp. 51-55.
¹⁰² *Id.*, at pp. 56-60.
¹⁰³ Additional Documents dated 19 May 2022 of Datascope Communications (Philippines), Inc., referred to as Privacy Impact Assessment at pp. 61-65.

		6. With procedure for pick up and transfer of hard drives aside from the logs recording the movement of the hard drives and chain of custody handling. 7. HRD Room is locked when unattended 8. Re-orientation of Data Privacy documents to all HR staff. 9. Implementation of disciplinary action. 10. Testing of backup external HDD.
Incomplete and inaccurate back up data on the HDD.	Operational Staff or User Errors due to lack of training.	Orientation of HR staff.
Theft of external HDD.	Lack of Physical Security.	HR room is locked when unattended and accessible only to HR personnel.
Loss of data due to loss of external HDD during transfer.	Lack of documentation during transfer	With gate pass upon transfer (noted by immediate superior and approved by ISMR)
Loss of data due defective back up hard drive.	Lack of testing of back up hard drives	Implementation of back up testing procedures.
Loss of Data/Information	Lack of user awareness.	Backup procedure.
Disclosure of sensitive information.	Theft of external HDD.	Storage of external HDD are stored in a secure storage and only authorized personnel has access.
Disclosure of sensitive information.	Loss of external HDD.	Storage of external HDD are stored in a secure storage and only authorized personnel has access.
Disclosure of sensitive information.	Uncontrolled copying of data.	Only the HR Analyst is authorized to copy/backup employee's personal data.

Thus, based on the records, Datascope has been able to conduct an adequate PIA in line with NPC Advisory 17-03, pursuant to the Order of CID dated 14 June 2021.

III. The incident falls under the mandatory breach notification requirement; Datascope

*sufficiently notified the affected
data subjects of the incident.*

In its initial report, Datascope stated that an external HDD containing scanned copies of personnel employment records went missing when the same was transferred from TARA Facility to MMP Facility.¹⁰⁴ Datascope specifically stated that the total number of affected data subjects is 651 broken down into: (1) 384 active employees; (2) 260 resigned employees; (3) 7 employees on leave.¹⁰⁵

Datascope also enumerated the personal data contained in the missing external HDD were: (1) full name; (2) date of birth; (3) address; (4) contact information; (5) SSS number; (6) tax identification number; (7) BIR Form 2316; (8) Philhealth number; (9) PAG-Ibig number; (10) education/transcripts/diplomas; (11) performance assessments; (12) disciplinary actions; (13) work history; (14) post-employment information; (15) hiring requirements; and, (16) annual medical records, among others.¹⁰⁶

In order to allow the affected data subjects to take “necessary precautions or other measures to protect themselves against the possible effects of the breach,” notification should be made upon them regarding the incident.¹⁰⁷ Thus, Rule V, Section 11 of NPC Circular 16-03 (Personal Data Breach Management) provides:

SECTION 11. When notification is required.

Notification shall be required upon knowledge of or when there is reasonable belief by the personal information controller or personal information processor that a personal data breach requiring notification has occurred, under the following conditions:

- A. The personal data involves sensitive personal information or any other information that may be used to enable identity fraud. For this purpose, “other information” shall include, but not be limited to: data about the financial or economic situation

¹⁰⁴ Mandatory Notification and Report dated 31 July 2018 of Datascope Communications (Philippines), Inc., at p. 2.

¹⁰⁵ Full Report on the Personal Data Breach dated 03 November 2020 of Datascope Communications (Philippines), Inc.

¹⁰⁶ Mandatory Notification and Report dated 31 July 2018 of Datascope Communications (Philippines), Inc., at p. 4.

¹⁰⁷ National Privacy Commission, Personal Data Breach Management, NPC Circular 16-03, rule V, § 18(A) (15 December 2016) (NPC Circular 16-03).

of the data subject; usernames, passwords and other login data; biometric data; copies of identification documents, licenses or unique identifiers like Philhealth, SSS, GSIS, TIN number; or other similar information, which may be made the basis of decisions concerning the data subject, including the grant of rights or benefits.

- B. There is reason to believe that the information may have been acquired by an unauthorized person; and
- C. The personal information controller or the Commission believes that the unauthorized acquisition is likely to give rise to a real risk of serious harm to any affected data subject.¹⁰⁸

The first requisite under Section 11 is present in this case considering that the missing external HDD contained scanned copies of personnel employment records which also contain sensitive personal information such as the dates of birth, annual medical records, education/transcripts/diplomas, disciplinary actions, among others.¹⁰⁹

Moreover, Section 20(f) of the DPA in relation to Section 11(A) NPC Circular 16-03 states:

SEC. 20. Security of Personal Information.-

...

(f) The personal information controller shall promptly notify the Commission and affected data subjects when sensitive personal information or **other information that may, under the circumstances, be used to enable identity fraud** are reasonably believed to have been acquired by an unauthorized person, and the personal information controller or the Commission believes that such unauthorized acquisition is likely to give rise to a real risk of serious harm to any affected data subject[.]¹¹⁰ (Emphasis supplied)

¹⁰⁸ NPC Circular 16-03, rule V, § 11.

¹⁰⁹ Mandatory Notification and Report dated 31 July 2018 of Datascope Communications (Philippines), Inc., at p. 4.

¹¹⁰ An Act Protecting Individual Personal Information in Information and Communications Systems in the Government and the Private Sector, Creating for This Purpose a National Privacy Commission, and for Other Purposes [Data Privacy Act of 2012], Republic Act No. 10173, chapter V, § 20(f) (2012).

It must be stressed that the “other information that may be used to enable identity fraud” as defined in Section 11(A) of NPC Circular 16-03 is not an exclusive list.¹¹¹ In this instance, while the employees SSS numbers, tax identification numbers, and PhilHealth numbers are among those specified in Section 11(A) of NPC Circular 16-03, BIR Forms 2316 and Pag-IBIG numbers¹¹² are likewise considered “other information that may be used to enable identity fraud,” under this circumstance which, according to Datascope can result into identity theft of personal data which can be used for blackmailing or extortion, and coercion, as well as access to personal data which can result to “reputation or financial damage or could be sold to telemarketers.”¹¹³

Further, there is a reason to believe that these information may have been acquired by an unauthorized person considering that based on the investigation conducted, Datascope “cannot establish whether the external HDD was misplaced or intentionally taken or at worst, stolen.”¹¹⁴ It can be deduced therefore that Datascope has lost control over the external HDD. Datascope also admitted that the personal data breach may result into identity theft and, access of personal data.¹¹⁵ Thus, since Datascope alleged that identity theft and, access thereof may result due to the loss of external HDD, there was already a belief on Datascope that such external HDD was acquired by unauthorized person. Hence, the second requisite is also present.

Consequently, the third requisite is also present, since the unauthorized acquisition of the external HDD containing personnel employment records are likely to give rise to a real risk of serious harm to the affected data subjects. It must be noted that there should exist a nexus between the data breach incident and the consequent real risk of serious harm that may possibly arise. The Commission has stressed that the “risk shall be apparent and not a product of mere speculation,” which means that the “consequences and effects

¹¹¹ NPC Circular 16-03, rule V, § 11(A).

¹¹² Mandatory Notification and Report dated 31 July 2018 of Datascope Communications (Philippines), Inc., at p. 4.

¹¹³ *Id.*, at pp. 3-4.

¹¹⁴ Full Report on the Personal Data Breach dated 03 November 2020 of Datascope Communications (Philippines), Inc., at p. 3.

¹¹⁵ Mandatory Notification and Report dated 31 July 2018 of Datascope Communications (Philippines), Inc., at pp. 3-4.

to any affected data subject is significant based on the surrounding circumstances of the breach.”¹¹⁶

In the surrounding circumstances of this case, the risk was apparent to the affected data subjects since according to Datascope, identity theft of the personal data contained in the lost external HDD is a possible negative consequence of the breach incident.¹¹⁷ Considering the nature and sensitivity of the personal data involved in this case, their unauthorized acquisition as well as their possible unauthorized access “can be used for illegal purposes like blackmail or extortion, coercion,” and “may result to reputation or financial damage or could be sold to telemarketer.”¹¹⁸

These being said, Datascope has more sufficient reason to notify the affected data subjects. Thus, given that all the requisites for mandatory notification requirement are present, Datascope, as PIC, has the obligation to notify the affected data subjects to reduce the possible risk arising from the incident and to prevent further unauthorized acquisition of the personal data involved in the breach.¹¹⁹

However, the Commission notes that Datascope sufficiently complied with this obligation. In its Full Report dated 03 November 2020, Datascope submitted proof of notification to the 651 affected data subjects who were its employees- active, resigned, or on leave.¹²⁰

The notification made by Datascope was in the form of an Internal Memorandum signed by its DPO.¹²¹ The said notification contained the list of personal data involved in the incident.¹²² The Memorandum likewise contained details as to nature of the breach,¹²³

¹¹⁶ In re: EasyTrip Services Corporation, NPC BN 17-028 & NPC BN 18-180, Resolution dated 11 May 2023.

¹¹⁷ Mandatory Notification and Report dated 31 July 2018 of Datascope Communications (Philippines), Inc., at pp. 3-4.

¹¹⁸ *Id.*

¹¹⁹ NPC Circular 16-03, rule V, § 18(A).

¹²⁰ Full Report on the Personal Data Breach dated 03 November 2020 of Datascope Communications (Philippines), Inc., at p. 7. See Annex “15” also referred to as Mandatory Personal Data Breach Notification to Data Subjects.

¹²¹ *Id.*, also referred to as Annex “15.”

¹²² *Id.*, also referred to as Annex “15,” at p. 1.

¹²³ *Id.*, also referred to as Annex “15,” at pp. 1-2.

likely consequences of the breach,¹²⁴ measures taken to address the breach,¹²⁵ measures taken to secure or recover the compromised personal data,¹²⁶ measures being taken to prevent recurrence of the incident,¹²⁷ the actions performed to mitigate possible harm or negative consequences of the incident,¹²⁸ and the contact information of Datascope's DPO for assistance.¹²⁹

As proof of the notification required under Section 18 of NPC Circular No. 16-03, Datascope submitted proof of receipt of the notification given to the affected data subjects.¹³⁰ The notification receipt contained the names of Datascope employees, together with their company positions and their respective signatures as proof that they were notified by Datascope of the personal data breach incident.

Given the foregoing, the Commission finds that Datascope has sufficiently notified the affected data subject pursuant to NPC Circular 16-03.

WHEREFORE, based on the foregoing, the Commission hereby resolves that the matter of NPC BN 18-140 "In re: Datascope Communications (Philippines), Inc." is **CLOSED**.

SO ORDERED.

City of Pasay, Philippines.
18 April 2024.

SGD
JOHN HENRY D. NAGA
Privacy Commissioner

¹²⁴ Full Report on the Personal Data Breach dated 03 November 2020 of Datascope Communications (Philippines), also referred to as Annex "15," at p. 2.

¹²⁵ *Id.*

¹²⁶ *Id.*, also referred to as Annex "15," at pp. 2-3.

¹²⁷ *Id.*, also referred to as Annex "15," at p. 3.

¹²⁸ Full Report on the Personal Data Breach dated 03 November 2020 of Datascope Communications (Philippines), also referred to as Annex "15," at p. 3.

¹²⁹ *Id.*, at p. 4.

¹³⁰ *Id.*, also referred to as Annex "15."

WE CONCUR:

SGD
LEANDRO ANGELO Y. AGUIRRE
Deputy Privacy Commissioner

SGD
NERISSA N. DE JESUS
Deputy Privacy Commissioner

Copy furnished:

MPT
Data Protection Officer
Datascope Communications (Philippines), Inc.

COMPLAINTS AND INVESTIGATION DIVISION
ENFORCEMENT DIVISION
GENERAL RECORDS UNIT
National Privacy Commission